

Unit 8

Security Management

Security Management

- **Security** refers to providing a protection system to computer system resources such as CPU, memory, disk, software programs and most importantly data/information stored in the computer system.
- A computer system must be protected against unauthorized access, malicious access to system memory, viruses, worms etc.

Security Management (contd..)

OS security encompasses many different techniques and methods which ensure safety from threats and attacks. Some of them are

- Performing regular OS patch updates.
- Installing updated antivirus.
- Scrutinizing all incoming and outgoing network traffic through a firewall.
- Creating secure accounts with required privileges only.

Security Problems

Some of the most common types of ***violations*** include:

Breach of Confidentiality - Theft of private or confidential information, such as credit-card numbers, trade secrets, patents, secret formulas, manufacturing procedures, medical information, financial information, etc.

Breach of Integrity - Unauthorized ***modification*** of data, which may have serious indirect consequences. For example a popular game or other program's source code could be modified to open up security holes on users systems before being released to the public.

Breach of Availability - Unauthorized ***destruction*** of data, often just for the "fun" of causing havoc and for bragging rites. Vandalism of web sites is a common form of this violation.

Theft of Service - Unauthorized use of resources, such as theft of CPU cycles, installation of daemons running an unauthorized file server, or tapping into the target's telephone or networking services.

Denial of Service, DOS - Preventing legitimate users from using the system, often by overloading and overwhelming the system with an excess of requests for service.

Security Problems (Contd..)

One common attack is ***masquerading***, in which the attacker pretends to be a trusted third party. A variation of this is the ***man-in-the-middle***, in which the attacker masquerades as both ends of the conversation to two targets.

A ***replay attack*** involves repeating a valid transmission. Sometimes this can be the entire attack, (such as repeating a request for a money transfer), or other times the content of the original message is replaced with malicious content.

Security Problems (Contd..)

There are various security problems in operating system out of them major security problems are:

- User authentication
- Program threats
- System threats

User Authentication

It is the process of identifying each user of the system and associating the permission with them.

1. Passwords: Passwords are the most common form of user authentication. If the user is in possession of the correct password, then they are considered to have identified themselves.

2 Password Vulnerabilities

a) Passwords can be guessed

- ❖ Intelligent guessing requires knowing something about the intended target in specific, or about people and commonly used passwords in general.
- ❖ Brute-force guessing involves trying every word in the dictionary, or every valid combination of characters. For this reason good passwords should not be in any dictionary (in any language), should be reasonably lengthy, and should use the full range of allowable characters by including upper and lower case characters, numbers, and special symbols.

b) "**Shoulder surfing**" involves looking over people's shoulders while they are typing in their password.

- ❖ Even if the lurker does not get the entire password, they may get enough clues to narrow it down, especially if they watch on repeated occasions.
- ❖ Common courtesy dictates that you look away from the keyboard while someone is typing their password.
- ❖ Passwords echoed as stars or dots still give clues, because an observer can determine how many characters are in the password.

User Authentication (contd..)

c)"**Packet sniffing**" involves putting a monitor on a network connection and reading data contained in those packets.

- ❖ SSH encrypts all packets, reducing the effectiveness of packet sniffing.
- ❖ However you should still never e-mail a password, particularly not with the word "password" in the same message or worse yet the subject header.
- ❖ Beware of any system that transmits passwords in clear text. ("Thank you for signing up for XYZ. Your new account and password information are shown below".) You probably want to have a spare throw-away password to give these entities, instead of using the same high-security password that you use for banking or other confidential uses.
- ❖ Long hard to remember passwords are often written down, particularly if they are used seldomly or must be changed frequently. Hence a security trade-off of passwords that are easily divined versus those that get written down. :-{
- ❖ Passwords can be given away to friends or co-workers, destroying the integrity of the entire user-identification system.
- ❖ Most systems have configurable parameters controlling password generation and what constitutes acceptable passwords.
 - They may be user chosen or machine generated.
 - They may have minimum and/or maximum length requirements.
 - They may need to be changed with a given frequency. (In extreme cases for every session.)
 - A variable length history can prevent repeating passwords.
 - More or less stringent checks can be made against password dictionaries.

User Authentication (contd..)

3.Encrypted Passwords

- ❖ Modern systems do not store passwords in clear-text form, and hence there is no mechanism to look up an existing password.
- ❖ Rather they are encrypted and stored in that form. When a user enters their password, that too is encrypted, and if the encrypted version match, then user authentication passes.
- ❖ The encryption scheme was once considered safe enough that the encrypted versions were stored in the publicly readable file `"/etc/passwd"`.
 - They always encrypted to a 13 character string, so an account could be disabled by putting a string of any other length into the password field.
 - Modern computers can try every possible password combination in a reasonably short time, so now the encrypted passwords are stored in files that are only readable by the super user. Any password-related programs run as `setuid root` to get access to these files. (`/etc/shadow`)
 - A random seed is included as part of the password generation process, and stored as part of the encrypted password. This ensures that if two accounts have the same plain-text password that they will not have the same encrypted password. However cutting and pasting encrypted passwords from one account to another will give them the same plain-text passwords.

User Authentication (contd..)

4 One-Time Passwords

- ❖ One-time passwords resist shoulder surfing and other attacks where an observer is able to capture a password typed in by a user.
- ❖ These are often based on a challenge and a response. Because the challenge is different each time, the old response will not be valid for future challenges.
 - For example, The user may be in possession of a secret function $f(x)$. The system challenges with some given value for x , and the user responds with $f(x)$, which the system can then verify. Since the challenger gives a different (random) x each time, the answer is constantly changing.
 - A variation uses a map (e.g. a road map) as the key. Today's question might be "On what corner is SEO located?", and tomorrow's question might be "How far is it from Navy Pier to Wrigley Field?" Obviously "Taylor and Morgan" would not be accepted as a valid answer for the second question!
- ❖ Another option is to have some sort of electronic card with a series of constantly changing numbers, based on the current time. The user enters the current number on the card, which will only be valid for a few seconds. A two-factor authorization also requires a traditional password in addition to the number on the card, so others may not use it if it were ever lost or stolen.

User Authentication (contd..)

- ❖ A third variation is a code book, or one-time pad. In this scheme a long list of passwords is generated, and each one is crossed off and cancelled as it is used. Obviously it is important to keep the pad secure.

5 Biometrics

- ❖ Biometrics involve a physical characteristic of the user that is not easily forged or duplicated and not likely to be identical between multiple users.
- ✓ Fingerprint scanners are getting faster, more accurate, and more economical.
- ✓ Palm readers can check thermal properties, finger length, etc.
- ✓ Retinal scanners examine the back of the users' eyes.
- ✓ Voiceprint analyzers distinguish particular voices.
- ✓ Difficulties may arise in the event of colds, injuries, or other physiological changes.

Program Threats

OS system's processes and kernel do the designated task as instructed. If a user program made these process do malicious tasks, then it is known as Program Threats. Some of the well-known program threats are:

- Trojan Horse
- Trap Door
- Stack and buffer overflow
- Virus etc.

Program Threats (contd..)

1 Trojan Horse

- A ***Trojan Horse*** is a program that secretly performs some maliciousness in addition to its visible actions.
- Some Trojan horses are deliberately written as such, and others are the result of legitimate programs that have become infected with ***viruses***, (see below.)
- One dangerous opening for Trojan horses is long search paths, and in particular paths which include the current directory (".") as part of the path. If a dangerous program having the same name as a legitimate program (or a common mis-spelling, such as "sl" instead of "ls") is placed anywhere on the path, then an unsuspecting user may be fooled into running the wrong program by mistake.
- Another classic Trojan Horse is a login emulator, which records a users account name and password, issues a "password incorrect" message, and then logs off the system. The user then tries again (with a proper login prompt), logs in successfully, and doesn't realize that their information has been stolen.

Program Threats (contd..)

2 Trap Door

- A **Trap Door** is when a designer or a programmer (or hacker) deliberately inserts a security hole that they can use later to access the system.
- Because of the possibility of trap doors, once a system has been in an untrustworthy state, that system can never be trusted again. Even the backup tapes may contain a copy of some cleverly hidden back door.
- A clever trap door could be inserted into a compiler, so that any programs compiled with that compiler would contain a security hole. This is especially dangerous, because inspection of the code being compiled would not reveal any problems.

3 Stack and Buffer Overflow: This is a classic method of attack, which exploits bugs in system code that allows buffers to overflow. Consider what happens in the following code, for example, if `argv[ 1 ]` exceeds 256 characters:

- The `strcpy` command will overflow the buffer, overwriting adjacent areas of memory.

(The problem could be avoided using `strncpy`, with a limit of 255 characters copied plus room for the null byte.)

4 Logic Bomb: It is a piece of code intentionally inserted into a software system that will set off malicious function when specified conditions are met. For example: a programmer will hide a piece of code that start deleting files, should they ever be terminated from the company.

System and Network Threats

A system threat refers to the misuse of system services and network connections to put user in trouble. It creates such an environment that OS resources/user files are misused.

Some of the well-known system threats are:

- Worm
- Viruses
- Port scanning
- Denial of Service etc.

System and Network Threats (contd..)

a)Worms

- A **worm** is a process that uses the fork / spawn process to make copies of itself in order to wreak havoc on a system. Worms consume system resources, often blocking out other, legitimate processes. Worms that propagate over networks can be especially problematic, as they can tie up vast amounts of network resources and bring down large-scale systems.
- One of the most well-known worms was launched by Robert Morris, a graduate student at Cornell, in November 1988. Targeting Sun and VAX computers running BSD UNIX version 4, the worm spanned the Internet in a matter of a few hours, and consumed enough resources to bring down many systems.
- This worm consisted of two parts:
 - A small program called a **grappling hook**, which was deposited on the target system through one of three vulnerabilities, and
 - The main worm program, which was transferred onto the target system and launched by the grappling hook program.

System and Network Threats (contd..)

b) Viruses

- A virus is a fragment of code embedded in an otherwise legitimate program, designed to replicate itself (by infecting other programs), and (eventually) wreaking havoc.
- Viruses are more likely to infect PCs than UNIX or other multi-user systems, because programs in the latter systems have limited authority to modify other programs or to access critical system structures (such as the boot block.)
- Viruses are delivered to systems in a ***virus dropper***, usually some form of a Trojan Horse, and usually via e-mail or unsafe downloads.

System and Network Threats (contd..)

c)Denial of Service

- *Denial of Service (DOS)* attacks do not attempt to actually access or damage systems, but merely to clog them up so badly that they cannot be used for any useful work. Tight loops that repeatedly request system services are an obvious form of this attack.
- DOS attacks can also involve social engineering, such as the Internet chain letters that say "send this immediately to 10 of your friends, and then go to a certain URL", which clogs up not only the Internet mail system but also the web server to which everyone is directed. (Note: Sending a "reply all" to such a message notifying everyone that it was just a hoax also clogs up the Internet mail service, just as effectively as if you had forwarded the thing.)
- Security systems that lock accounts after a certain number of failed login attempts are subject to DOS attacks which repeatedly attempt logins to all accounts with invalid passwords strictly in order to lock up all accounts.